Step 1 — A Normal RAG Agent, and Proving It's Vulnerable — Hints

> Back to the step · Hint 1 · Hint 2 · Solution

- Hint 1 — The idea, and the exact pieces
- Hint 2 — The plan, and the one thing to get right

Hint 1 — The idea, and the exact pieces

Build a plain RAG + tool agent with **zero** defenses, then watch it fall. The pieces (all Doc06/08 shapes):

- `src/config.py`, `src/exceptions.py`, `src/utils/logger.py` — the Doc01 trio.
- `src/rag/chunking.py` (`chunk_by_paragraph`), `src/rag/store.py` (`get_collection`), `src/rag/ingest.py` (`load_documents`, `build_vector_store`), `src/rag/retriever.py` (`retrieve(collection, query, k=3) -> list[dict]`).
- `src/tools/email_tool.py` — a mock `send_email(to, subject, body)` that only logs, plus `SEND_EMAIL_SCHEMA` (Doc06's shape).
- `src/models/llm.py` — `create_client` and `chat_with_tools(client, system, user)` running the tool loop.
- `src/agent.py` — `run_agent(client, collection, question)` that pastes the **raw** retrieved text into the prompt.

The planted doc (`data/docs/policy_expenses.md`) hides the instruction mid-paragraph, in the document's own tone — not a shouted, obviously-fake line.

Hint 2 — The plan, and the one thing to get right

```
retrieve(collection, question) -> [{text, source}, ...]
run_agent (UNDEFENDED):
    context = "\n".join(chunk["text"] for the chunks)   # RAW, no labels
    user = "Context:\n" + context + "\n\nQuestion: " + question
    answer, tool_calls = chat_with_tools(client, PLAIN_SYSTEM, user)
main.py: run the expense question, print the answer, check for the fake text
```

The one thing to get right: **paste the retrieved text in raw**, with no `<retrieved_context>` wrapping and no system-prompt rule about data-vs-commands. That's what makes Step 1 genuinely vulnerable. If the model refuses the injection anyway, the attack isn't blending in — make it match the surrounding document's tone, put it mid-paragraph, and avoid words like "hack" that read as a test rather than real content. This step isn't done until you've watched it produce the fake shutdown message.

The whole file set is in the Solution.